

ARA - Access Risk Analysis

VIRSA 4.0 ----- > Compliance Calibrator (CC)

GRC AC 5.1, 5.2, 5.3 ----- > Risk Analysis & Remediation (RAR)

GRC AC 10, 10.1,12 ----- > Access Risk Analysis (ARA)

What is difference between ARA (AC) and RM (GRC)?

ARA – Access Risk Analysis - Component of AC (AC – Comp of GRC)

which deals with Risks related to SAP **Access/Authorizations**

GRC --- > Access Control (AC) ---- > ARA

GRC ---- > Risk Management (RM)

RM – Risk Management - Component of GRC, which deals with overall risks in Org

- Strategic Risk.
- Compliance Risk.
- Operational Risk Ex, COVID
- Financial Risk.
- Reputational Risk
- Cyber Risk - IT

Risk: **Futuristic** - Something which impacts your business – Financial/ Reputational/Operational/Natural/IT

Ex, Smoking is a **risk** to your lungs

- **Probability** – Chances of its occurrence – Depends on **Experience** or knowledge

Ex, **Betting** – 50% probability of Losing

- **Risk is not universal** – Risk depends on local factors- It varies from company to company or location or Business

Power Sector:

X Company ---- > A, B, C (3) Customers

A Company ---- > 10,000 Customers

Finance Risk:

Payment Received + Payment Adjustment

Due Date:

A1 --- > 30th of every month --- > Paid on 10th Itself

A2 ---- > 15th of every month --- > Fine

ARA deals with only SAP Access/Authorization related risks.

Terminology:

Action ----- > T-code

Permission ----- > Auth Values (Auth Objects, Auth Fields and Values)

- ❖ Access Risk – Identification – **Risk Analysis & Simulation**
- ❖ Access Risk – Remove or Avoid – **Risk Remediation**
- ❖ Access Risk – Reduce its impact/Control – **Risk Mitigation**

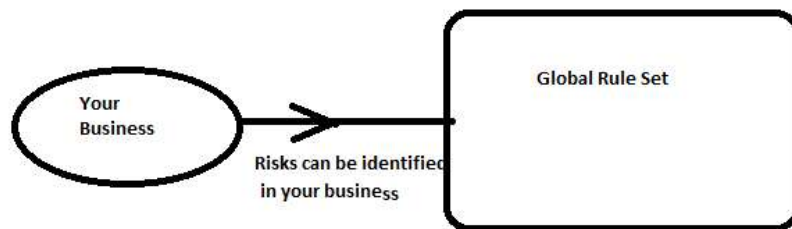
Risk Identification:

To identify a Risk – **Experience/Knowledge** – Self or Others

SAP has studied famous companies in the world, domain wise –
Banking, Automobile, Retail etc. – Gathered the risks faced by this
companies and that has been documented – **Global Rule Set**

Global Rule Set – It is database of **Access Risks**, faced by reputed companies in the last 100 years and risks have been Organized process wise (Finance, HR, Sales...)

Note: This risk data can be loaded into your system through BC sets related to **GRAC*RULESET*** activation. (TCODE: **SCPR20**)



Risk Types:

- 1) **SOD Risk** – Combination of **conflicting** functions –

Ex,

Security Admin + Client Admin

F017 = Maintain bank Account + divert Incoming payments

Action Level = **SU01+SCC4**, SCC4+STMS

Action level= FI01/FI02 + F-84

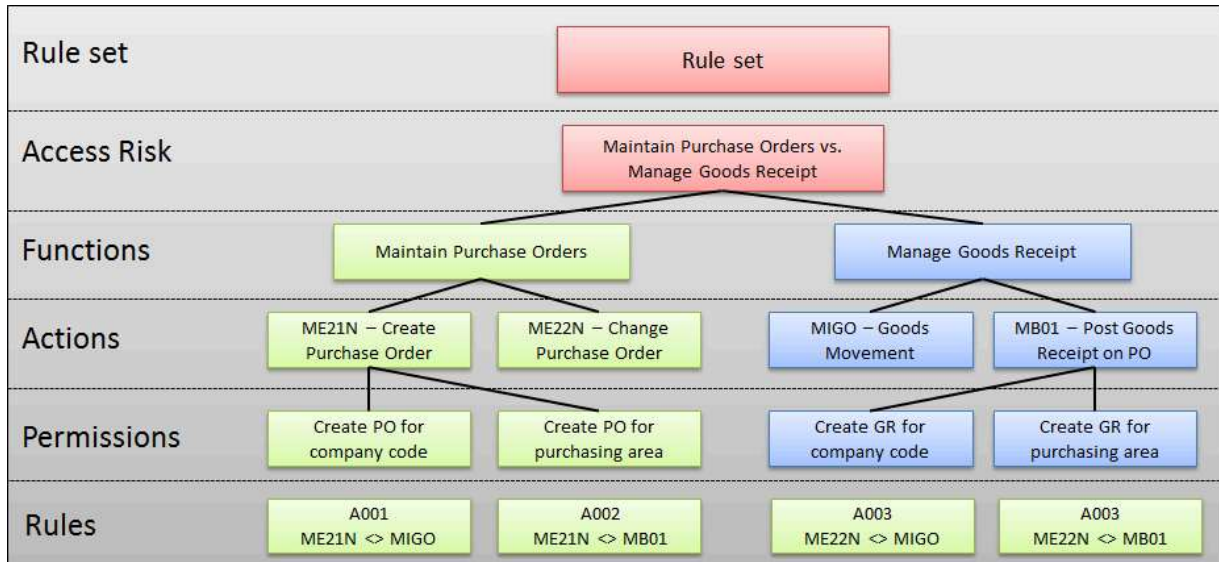
, ME21N+MB01, FB01+FBVO

Permission Level = **Auth Values of SU01 with**

Activity:01/02/05/06/22 + Auth Values of SCC4 with Activity:01/02

- 2) **Critical Action Risk** – SCC5, SE38, SPRO

- 3) **Critical Permission Risk** – SCC5: S_TABU_DIS with Activity 01 or 02, SE38: S_DEVELOP With Activity:01 or 02 or 03



SU22 --- > SAP Standard Auth Checks (reference guide)

SU24---> SAP standard Data (SU22) + Cust Data ---- > PFCG

GLOBAL Ruleset ---> SAP STANDARD (reference guide)

CUSTOM Ruleset ---- > GLOBAL + CUST (deactivate some existing risks and Create some new Risk)

Why do we go for Custom Rule set?

- 1) To define new Risks which are not part of GLOBAL

Ex, Custom T-codes, new Business

- 2) All Risks in GLOBAL may not be applicable to our Business.

Steps to create custom rule set:**1. Rule set Creation:**

NWBC ----- > SET UP ----- > Access Rule Maintenance ----- > Rule Set

Create a Custom Rule set as per your Client Requirement - Name

2. Business Processes: (Departments)

SPRO ----- > GRC ----- > Access Control ----- > Maintain Business process and Sub processes

3. Function Creation:

NWBC ----- > SET UP ----- > Access Rule Maintenance ----->Functions.

ECC - ECCCLNT100

BW - BWCLNT100

HR - HRCLNT100

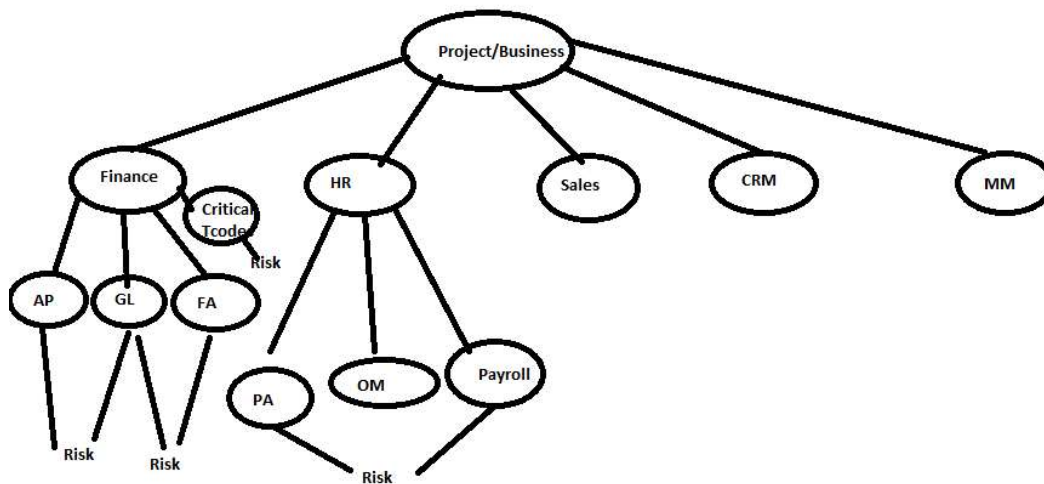
ARA: Risk Analysis Function Creation

TYT_GROUP

ECCCLNT100

BWCLNT100

HRCLNT100



4. SOD Risk at Action Level:

To create a SOD risk, we need Business process, 2 functions and T-codes/Auth data in Functions.

Ex, Business Process ----- > **BASIS** (TYT_IT)

Path: SPRO --- > GRC ----- > AC ----- > Maintain BPs and Sub Processes

Functions ----- > **TYT_SEC**:SU01, PFCG, SU10

TYT_CLAD: SCC4, SCC5, SCCL, SCC9

SOD Risk: **TYT_SOD1** = **TYT_CLAD** + **TYT_SEC**

EX, SU01 + SCC4 combination is a Risk.

SU01 = User Maintenance

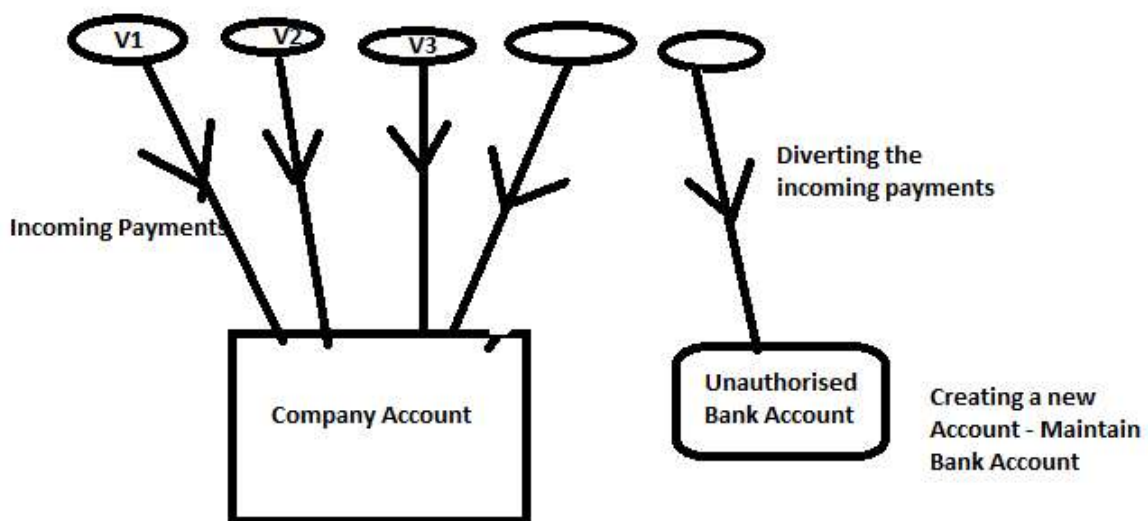
SCC4 = Client Creation

Once the Risk ID is created, we need to generate the rules

Rules = Risk causing combinations Ex,, SU01+SCC4

SOD Risk example:

Finance Risk: **F017**---- > Maintain bank account and divert incoming payments



SOD Risk at Permission Level:

SU01+SCC4 --- > SOD RISK at Action level

SU01 --- > User Creation/Modification/Deletion

S_USER_GRP with ACTVT: 01 or 02 or 06

SCC4 ---- > **Client Creation/Modification**

S_TABU_DIS with Auth group: SS and Activity: 02

Or

S_TABU_NAM with Table Name: T001 and Activity: 02

User1: SU01 Display + SCC4 Display ---- > No risk

User2: SU01 FULL + SCC4 Act Display ---- > No risk

User3: SU01 Display + SCC4 FULL ---- > No risk

User4: SU01 ACTVT 01 and 02 + SCC4 Act 02 --- > Risk

User5: SU01 ACTVT 02 + SCC4 Act 01 --- > Risk

User6: SU01 ACTVT 06 + SCC4 Act 01 --- > Risk

User7: SU01 ACTVT 01,02,05,06,22 + SCC4 Act 01 --- > Risk

User5: PFCG FULL + SCC4 Act 01 --- > SOD RISK

User6: PFCG FULL + SCC4 Act 02 --- > SOD Risk

SCC4

S_TABU_DIS

ACT:02 or 01/01 & 02

AUTH GROUP: SS

Relation between 2 Auth Objects is always **AND**

Relation between 2 or more values of Field under One Auth Object can be **OR/AND**

Relation between 2 fields of one Auth Object is always **AND**

Critical Action Risk:

To create a Critical Action Risk, we need one function which contains all critical **T-codes** in that Business process.

BMW_CAF: SPAM, SPRO, SU25, SCC5, SU24, BP

BMW_CAR1 ---- > BMW_CAF

Critical Permission Risk:

To create Critical Permission Risk, we need one function which contains all critical **Auth Values** – Auth Objects, Auth Fields and Values

(No T-codes)

MRF_CPF:

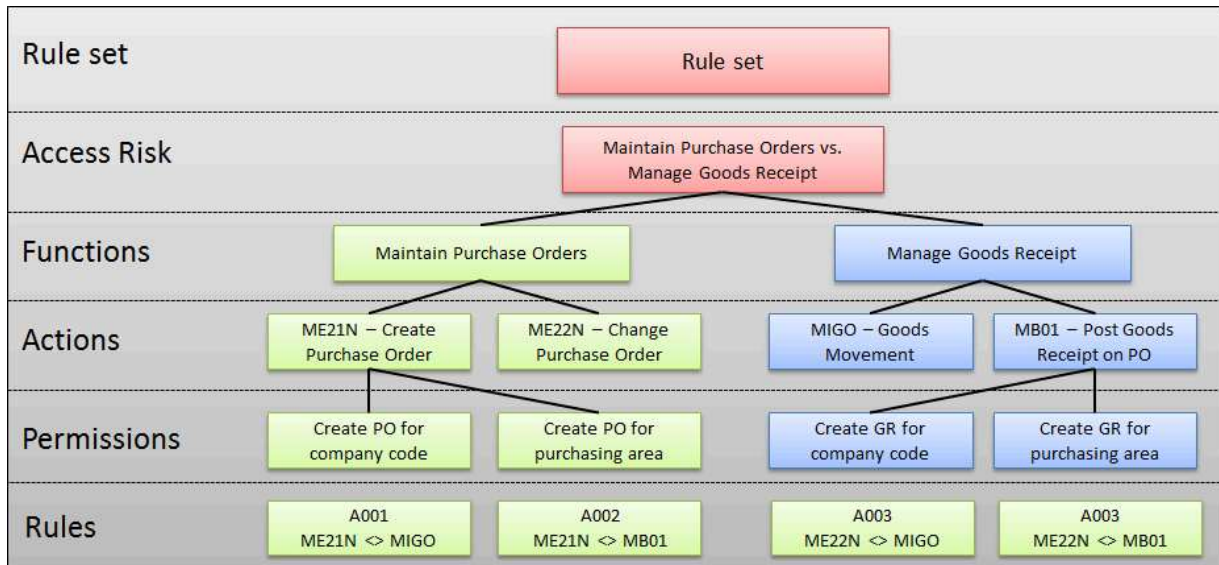
SCC5: S_TABU_CLI with CLIENTMAINT: X

SE38: S_DEVELOP with ACTVT: 01 or 02

MRF_CPR1 ----- > MRF_CPF

Action = T-code

Permission = Auth Values



Risk Levels: (based on impact done to business)

- 1) **Low** – SOD Risk – FI,MM,SD,WM,Etc
- 2) **Medium** - SOD Risk - FI,MM,SD,WM,Etc
- 3) **High** – SOD Risk – FI,MM,SD,WM,Etc, SOD related to BASIS, Sec, ABAP- ADMIN (IT)
- 4) **Critical** – Critical Action Risks, Critical Permission Risks

EX,,

Finance team – Low, Medium and HIGH SOD risk

BASIS – HIGH SOD Risk

Risk Analysis path:

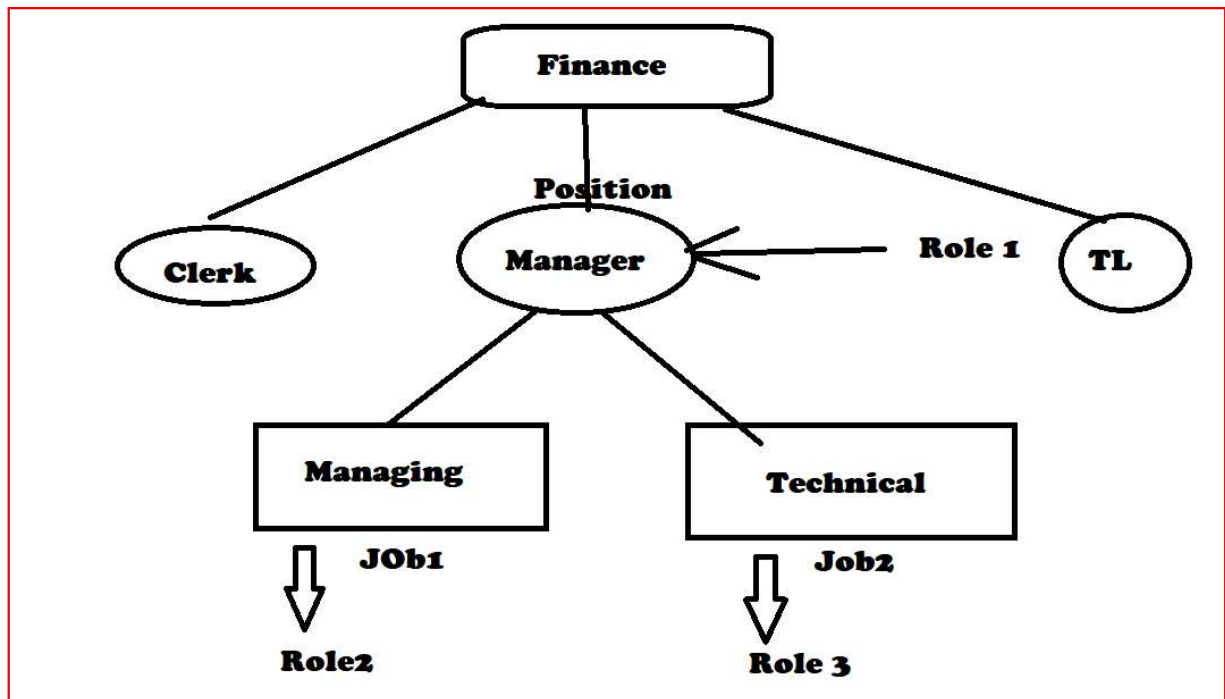
NWBC ----- > Access Management ----- > Access Risk Analysis

Risk Analysis Report Formats:

- **Detail** – gives you max info
- Summary
- Management Summary
- Executive Summary

Risk Analysis Levels:

- 1) User Level
- 2) Role Level
- 3) HR Objects Level – Position(designation)/Org Unit (Dept)/Job
- 4) Profile Level – Not used



Which is preferable: User Level or Role Level?

Role Level Risk Analysis ----> to detect Critical Action/Permission Risk

Role1: SCC4, SCC5, PFCG

SOD at Action level --- Remove PFCG

SCC4+PFCG--- > SOD risk

SCC5+PFCG----> SOD risk

Role 1: SCC4, SCC5 ---- > SCC5 --- > Critical Action Risk – Remove SCC5

ROLE1: SCC4 --- > USER

Critical Action Risk ---- > Remove SCC5

SCC5 ----- > Critical Action Risk

Role1: SCC4

User:

Role1 --- > SCC4 --- > No RISK

Role2 --- > PFCG ----- No risk

SOD Risk:

SCC4+PFCG

Role level

SOD Risk

Critical Action Risk

Critical Permission Risk

User Level

SOD Risk

Role Administration: Role level

Role creation ---- > Risk Analysis

Role modification --- > Add/Remove ---- > Risk Analysis for only adding Access

Role Deletion --- > NO

ROLE 1--- > SCC4, SU01, PFCG, SU53

SCC4+SU01 --- > RISK1

SCC4+PFCG --- > RISK2

Remove SU53

SCC4+SU01 --- > RISK1

SCC4+PFCG --- > RISK2

Remove PFCG

SCC4+SU01 --- > RISK1

Remove Su01

SCC4+PFCG --- > RISK2

Remove SCC4

No Risk

User Administration: User Level

User Creation --- > YES

User Modification --- > ADD role /Remove Role --- > Yes for Adding

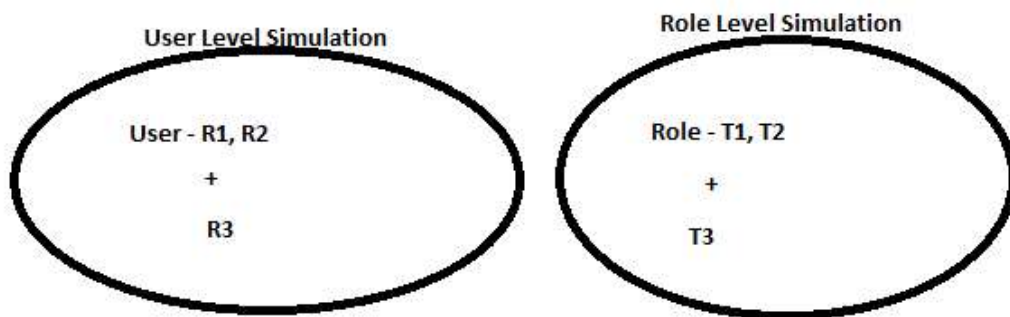
User Lock --- > No

User Unlock ---- > YES

User Delete ---- > No

Risk Simulation:

- User Level = Whenever User asks for extra access (Role/T-code)
- Role Level = Whenever role must be modified (adding/removing t-codes from Single role or adding/removing Single roles from Comp role)



Risks from Simulation Only? ----- > To check the risks coming due to **adding** of a t-code/role/profile to user (It does not show already existing risks)

Include: For Assignment of Access

Exclude: For removal of existing access

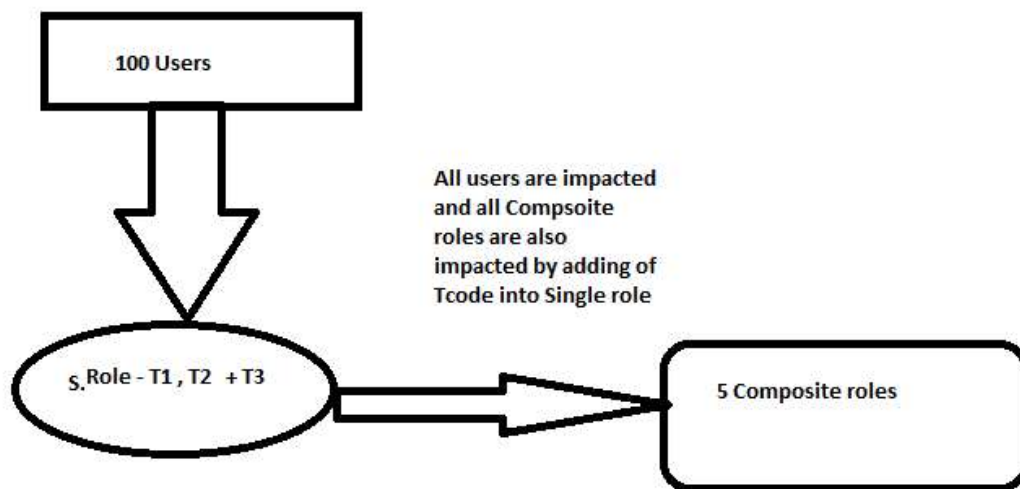
Exclude Values? ----- >To check left over risks, when T-code/role/profile is **removed** from User. (Ensure that T-code/Role should be assigned to User already)

Simulation can be done in 2 levels.

- User level

➤ Role level

Role Level Simulation:



Defining Risk Owner:

Risk Owner:

Risk Owners are assigned to risks and are commonly responsible for approving **changes to risk definitions** and **violations of the risk**. Risk Owners may also receive conflicting and critical action alerts.

Steps to define Risk Owner:

- 1) Ensure the user id is present in the **GRC system** with the necessary Authorizations.
- 2) Declare that user id as **Risk Owner** in the below path

NWBC ---- > SET UP ----- > Access Owners ---- > Access Control
Owners

- 3) Open the Risk ID and define the above id as Risk owner for that Risk ID

When Risk Owner leaves the ORG, what are your roles and responsibilities?

1. Creating a new risk Owner in GRC system
2. Declare risk owner in NWBC.
3. Update Risk Id with new Risk owner replacing Old Risk Owner
4. Terminate old Risk owner (delete/Lock/Expire)
5. Remove Risk owner from NWBC.

Risk Analysis Report is sent to **Risk Owner** in 2 ways

- Manual – Download the report and send mail.
- Automated – ARM Concept – Access request Workflow

1st Priority/Option: To **Rem**ediate Risk (**Rem**oval of a Risk)

2nd Priority/Option: Mitigate Risk (Risk Reduction/ Control Risk)

Traffic light Junction:**Risk: Jumping the Traffic junction**

- No CC Cam --- > HIGH
- YES CC Cam ---- > LOW

Traffic Violation ---- > Client Deletion

Jail or Fine ---- > No promotion/No Bonus/ Termination

Risk Remediation:

It means removing risk by removing access.

How to remove access to users?

- Risk must be removed.
- Users should not be impacted on their daily operations.

1) **Role modification** - Remove the risk causing T-code/Auth Values from the role that is assigned to user - **Multiple Users**

2) **Role removal** from the user - Unassign the role - **SINGLE USER**

USER1

ROLE1--- > SU01, PFCG

ROLE2 ---- > SCC5, SCC4, SCC7

USER1

ROLE1 (Sec)--- > SU01, PFCG, SCC5, SCC4, SCC7

Role Modification Request

Remove SCC5, SCC4, SCC7 from security Role

When you run risk analysis to all users in System

MRF_SOD1 is available to 100 users

MRF_RSK1 is due to Client Admin and SEC Admin

100 users = 20 BASIS Team + 80 non-BASIS Team

There is only one role assigned to 100 users.

User Admin role is assigned to 100 Users (BMW_USER1)

SE09+SCC4 = Z: SOD_RISK: BMW

SE09+SCC5 = Z: SOD_RISK: BMW

Su01 ---- > USER Admin Role

SCC4, SCCL ---- > Client Admin Role

BMW_USER1 belongs to which Team?

1) FINANCE ----- > Remove Access

2) BASIS ----- > cannot remove, may be DISPLAY/ either TMS or CLIENT ADMIN removed

3) Security ----> Remove Access

Removing User Admin Access:

#####

1) Remove SE09 from BASIS Admin Role???? Role Modification?? Approvals???

2) Create Another Role ---- > PROCESS ?? APPROVAL ???

3) Remove BASIS Admin Role ----> Other tcodes are also lost, Search for role

which does not contain SE09 and assign that Role to the user.

Risk Mitigation:

Reducing the probability of its occurrence or impact of the risk –
Controlling the risk

How? By monitoring mechanisms

HR User

Tcode1 - Modify Payroll Data --- > Basic Salary: 10K --- > 100000000K

Home Allowance: 1K

Shift allowance: 0.2K

Tcode2 - Process payroll ---- > Send money to Employee bank Account

How to control this **HR user**?

Mitigation: Manager must review the payroll Changes before processing it

Mitigation:

Monitor the user from misusing access ---> Manager

Mitigation Controls

- Specific to Business Process (HR, FIN, SD, MM, BASIS)
- Specific to **Organization Hierarchy** (Country/Region/Business Specific)
- Ex, **GDPR** – General Data Protection Regulation – EU

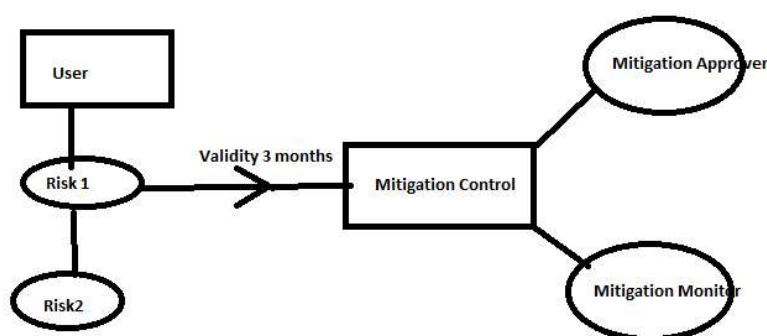
Residency

☐ I am residing in the EU or Switzerland

☐ I am not residing in the EU or Switzerland

Mitigation Approver (Risk Owner) – Responsible for approvals to assign Mitigation Controls for Users and approving changes to Mitigation Control Definition

Mitigation Monitor – Responsible for monitoring the mitigated users who have risks in the form of Alerts and Notification.



BASIS	Risks	Mitigation Control	Approver	Monitor
	BS_RISK1	BS_DB_MIT1	A1	M1
	BS_RISK2	BS_DB_MIT1	A1	M1
DBA	BS_RISK3	BS_DB_MIT1	A1	M1
	BS_RISK4	BS_DB_MIT1	A1	M1
	BS_RISK5	BS_DB_MIT1	A1	M1
	BS_RISK6	BS_MIT2	A2	M2
	BS_RISK7	BS_MIT2	A2	M2
SYSADM	BS_RISK8	BS_MIT2	A2	M2
	BS_RISK9	BS_MIT2	A2	M2
	BS_RISK10	BS_MIT2	A2	M2
	BS_RISK11	BS_MIT3	A3	M3
	BS_RISK12	BS_MIT3	A3	M3
OSA	BS_RISK13	BS_MIT3	A3	M3
	BS_RISK14	BS_MIT3	A3	M3
	BS_RISK15	BS_MIT3	A3	M3
	BS_RISK16	BS_MIT4	A4	M4

SYSMON	BS_RISK17	BS_MIT4	A4	M4
	BS_RISK18	BS_MIT4	A4	M4
	BS_RISK19	BS_MIT4	A4	M4
	BS_RISK20	BS_MIT4	A4	M4

HR	Risks	Mitigation Control	Approver	Monitor
PA	HR_RISK1	HR_PA_MIT1	A5	M5
PA	HR_RISK2	HR_MIT1	A5	M5
PA	HR_RISK3	HR_MIT1	A5	M5
PA	HR_RISK4	HR_MIT1	A5	M5
PA	HR_RISK5	HR_MIT1	A5	M5
OM	HR_RISK6	HR_MIT2	A6	M6
OM	HR_RISK7	HR_MIT2	A6	M6
Payroll	HR_RISK8	HR_MIT3	A7	M7
Payroll	HR_RISK9	HR_MIT3	A7	M7
Payroll	HR_RISK10	HR_MIT3	A7	M7

Mitigation Control:

Steps

- 1) Ensure user ids exist in **GRC system** for **Mitigation Approver** and **Monitors**

Mitigation Approver Role: SAP_GRAC_CONTROL_APPROVER

Mitigation Monitor Role: SAP_GRAC_CONTROL_MONITOR

SAP_GRAC_ACCESS_REQUESTER
SAP_GRAC_CONTROL_MONITOR
SAP_GRAC_DISPLAY_ALL
SAP_GRAC_END_USER
SAP_GRAC_NWBC

- 2) Define/Declare them in GRC system as **Mitigation Approver** and **Monitor** in **NWBC** ----- > Set up ----- > Access Control Owners
- 3) Create **Root Org** in **SPRO** ---- > GRC ----- > Shared Master Data

(Mitigation Controls are specific to Org units) and related Child org if required under **NWBC ---- > SET UP ---- > Org.**

4) Define **OWNERS** for the ORG

5) Create Mitigation Control **NWBC ---- > SET UP ---- > Mitigation Controls**

Note: If any risk must be Mitigated, ensure there is Mitigation Control created for that specific risk.

Mitigation Control assignment Validity is controlled by a parameter under the below path

SPRO----- > GRC ----- > Access Control ----- > Maintain Configuration Settings

Parameter ID: 1011 ---- > Default Expiration time for Mitigation Control Assignment

Default Validity: 1 Year (365 days)

Process of mitigating risks: Assignment

- 1) Users have a risk.
- 2) Risk report is sent to **Risk owner** and decides to Mitigate, it must be approved by **Mitigation Approver**
- 3) If they decide to mitigate, we need to link the risk id with appropriate mitigation control.

- 4) If Mitigation control is not available for that particular risk, it's Security/GRC team duty to create Mitigation Control after checking with Mitigation owners (Approver +Monitor)
- 5) Ensure that every user risk is associated with some Mitigation Control otherwise that risk cannot be Mitigated.
- 6) Show how to Mitigate risk for a particular user.
- 7) Apply Mitigation for the user Risk and save it.
- 8) For the Same risk, Mitigation Approver or Monitor left the organization.
- 9) You need to update Mitigation Approver/Monitor for that Risk with new people.

Which is recommended? User level Mitigation or Role level Mitigation? Explain?

Batch Risk Analysis:

SPRO ----- > GRC ----- > AC ----- >Access Risk Analysis ---- > Batch Risk Analysis ----- > Execute Batch Risk Analysis

It is performing/running risk analysis for all users & roles in the system and updates the table **GRACMGRISKD** &dashboards under **Reports and Analytics Tab** under **NWBC**

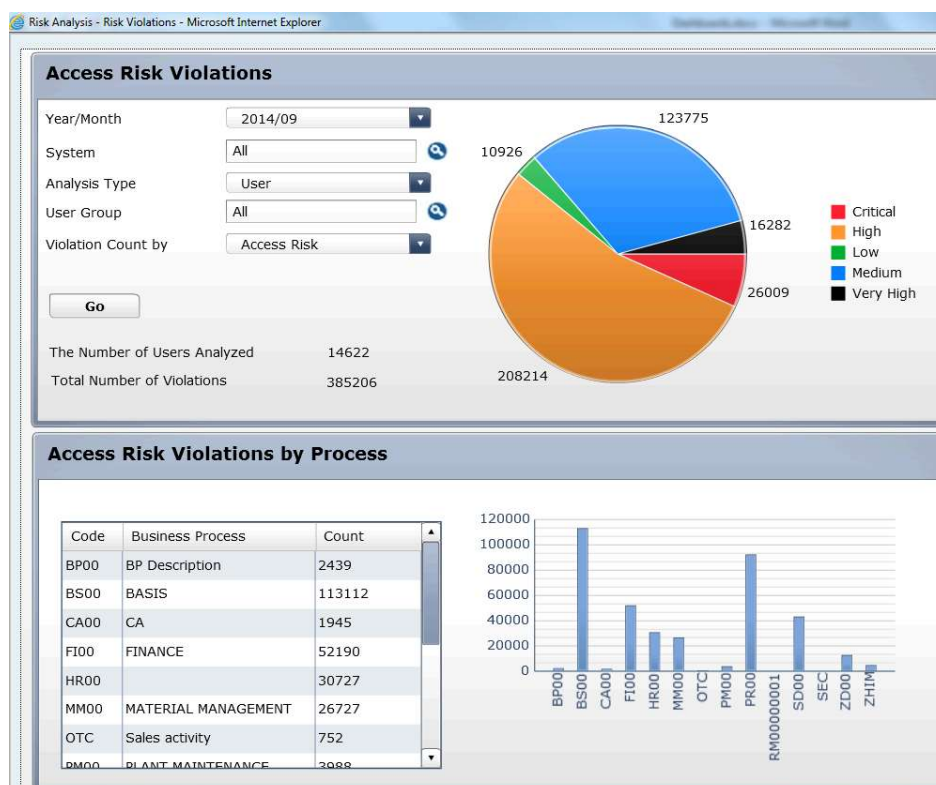
Purpose:

- 1) Risk Analysis Dashboards (reports)
- 2) Offline Risk Analysis
- 3) Risk Monitoring Job

Q: When the Risk (SOD Risk) Count increases from - 100 to 1000, what possible reasons could be for this increase?

Ans:

1. New t-codes are added to existing roles, which might cause SOD risk.
2. New roles are assigned to users
3. Mitigation Control Assignments are expired
4. New Users joined
5. Ruleset Modification



Risk Monitoring Job:

Today --- > 100 Risks Are there - ECC.

Tomorrow --- > 120 Risks Are there - ECC.

Reasons:

1. New Roles are assigned to Existing users
2. Some Mitigation Control assignments are expired
3. New T-codes added into Existing and assigned roles to users
4. New Users are created

What is the difference between **Offline Risk Analysis** and **Online Risk Analysis**?

Online Risk Analysis:

- GRC pulls the data from backend ECC and runs risk analysis.
- Accurate Data and updated data
- System performance – Late response
- If RFC error is there, this fails.

Offline Risk Analysis:

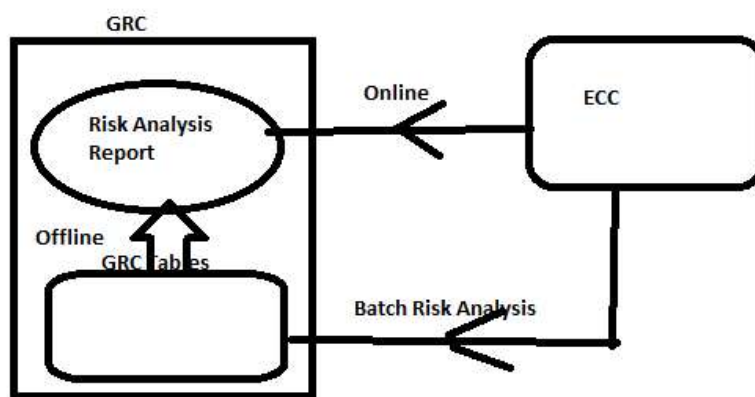
- GRC pulls the risk analysis data stored in Local GRC Tables-

GRACMGRISKD

(Dashboards) – These tables get updated by **BATCH RISK ANALYSIS** job.

- It may not be Accurate data and not updated.
- System performance – Fast response
- If there is RFC error, still we get the Risk Analysis Report.

Parameter ID: 1027 controls enabling the Offline Risk Analysis



What do you mean by False Positives?

There is no risk ideally, but GRC system shows a Risk as per the Rule set data defined.

SU53 is Risk ----> RISK

User 1 has SU53 ----> RISK

Example1: 2 conflicting functions have same T-code.

AP02 --- > Process vendor Invoice --- **FB01** – Post Document (Vendors-K)

GL01 ---->Post Journal Entry ---- **FB01** – Post Document for (GL Account -D)

Risk ID: F028 (SOD RISK) ---- > AP02+GL01

User: FB01

Risk Analysis

SOD RISK = F028 = FB01 (AP02) + FB01 (GL01)

Solution: Activate appropriate permission values as the per function definition

Example2: Finance SOD Risk

Action Level Rule: Create Invoice (**FB01**) & Approve Invoice (**FBV0**)

Permission Level Rule:

FB01 ---- >AO1 with Activity: 01/02

FBV0 ----- > AO2 with Activity: 43 Approve

User1

Role1: FB01 --- > F_BKPF_BUK with Activity 01,10 Company: 1000, 300(INDIA)

Role2: FBV0 ---- > AO2 with Activity: 43 Approve, Company: 2000 (Japan)

How to avoid FALSE POSITIVES?

1) **Org rules** need to be defined.

Org Rule1: AO1 with Act: 01,10 & CC: 100

AO2 with Act: 43 & CC: 100

Org Rule2: AO1 with Act: 01,10 & CC: 200

AO2 with Act: 43 & CC: 200

Note: System takes more time when running risk analysis as it must consider extra rules like Org Rules, Supplementary Rules other than Action rules, permission rules, etc.....

2) Create **Dummy and temporary Mitigation Control** and Mitigate the Risk

SOD Rules/ Rule set Upload/Download and Transports:

How do I move data from GRC Dev to QA and then to PROD??

- Transport
- Download and Upload

Transports:

What type of Transport Request is needed to move Rule set?

Ans: Workbench TR

Path: SPRO ---- > GRC ---- > Access Control ----- > Risk Analysis --- > SOD Rules --- > Transport SOD Rules

Note: After importing into target system (Dev --- > qua --- > Prod), generate the rules for all Risk Ids.

Path: SPRO ---- > GRC ---- > Access Control ----- > Risk Analysis --- > SOD Rules --- > Generate SOD Rules

How to Copy Global Ruleset data into Custom Ruleset Data?

Hints:

- Standard risks should be part of Custom Ruleset
- Standard Functions should have your Connector (System)/Connector group name

Ans:

- Create a Custom Ruleset under the below path

- NWBC ----- > SET UP ----- > Access Rule Maintenance ----- > Rule Sets
- **Download Global Ruleset** ---> Execute T-code
GRAC_DOWNLOAD_RULES by selecting system as SAP_R3_LG or SAP_S4A_LG
- Take a backup of the data downloaded
- Update the Risk and Ruleset relationship file
- Upload back by choosing your Connector (System)/Connector group ---- > **GRAC_UPLOAD_RULES**
- Generate the Rules for the Risks

Purpose:

- 1) To move data from Dev to QA & PROD
- 2) To modify the rule set data - **Mass Changes**

Upload Rules:

GRAC_UPLOAD_RULES

Download Rules:

GRAC_DOWNLOAD_RULES

Creating new Risks IDs:

What files need to be updated?

- Function
- Function Actions
- Function Permissions
- Function Business Process
- Risk
- Risk Description
- Risk Rule Set relationship
- Risk Owner – Optional

Create a new Business Process:

- Business Process

Create a new Function:

- Function
- Function Business Process
- Function Actions
- Function Permissions

When do you do Risk Analysis?

User Administration – User Creation, Modification

Role Administration – Role creation, modification

Maintaining Rule set – BP, Functions and Risk ids

Mitigation Control Maintenance – Creation and Modification

Maintaining Approvers – Risk Owner, Mitigation Approver/Monitor

Parameters Config – Risk Analysis, Mitigation